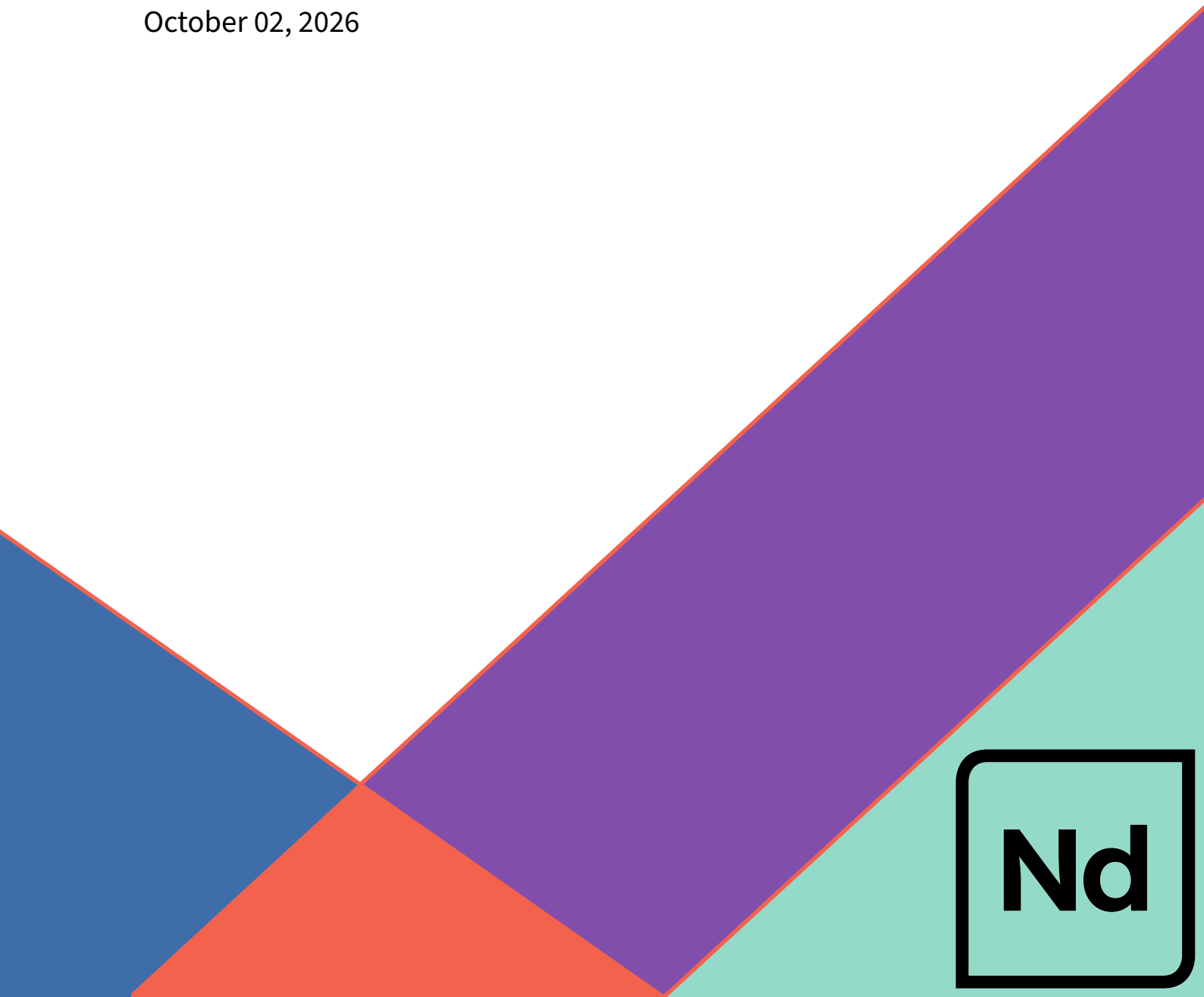

Code Review - Solana Stake Pool PRs #883 and #884

conducted by Neodyme AG

Auditor: Sebastian Fritsch

October 02, 2026



Nd

1 | Executive Summary

Neodyme performed a security review of two changes to the Solana Stake Pool program. The initial changes were reviewed on September 8, 2026, and the follow-up mitigations were verified on September 30, 2026.

Neodyme identified no security vulnerabilities in the reviewed changes. PR #883 correctly enforces the user's slippage limit against the final withdrawal amount. PR #884 is technically sound, but intentionally introduces a new trust assumption: The freeze authority of a pool mint can now prevent a user from withdrawing from withdrawing his stake. This behavior is disclosed to users through the official CLI and documentation.

The review was limited to the pull requests. It was not a comprehensive audit of the Stake Pool program.

2 | Scope

Reviewed Changes

Repository	Change	Role	Commit
stake-pool	PR #883: move the withdrawal slippage check	Primary	8d966f18
stake-pool	PR #884: permit pool mints with a freeze authority	Primary	3c165898
stake-pool	PR #931: update obsolete freeze-authority language	Mitigation	be160fa8
stake-pool	PR #932: require CLI opt-in for freezable pool tokens	Mitigation	9e98afa9
documentation	PR #36: document freezable pool tokens	Mitigation	3aabe63e

Review Focus

The review considered:

- correctness of the final-output slippage check during stake withdrawal;
- the security and trust-model consequences of permitting a pool mint with a freeze authority

Third-party dependencies, custom clients and unrelated Stake Pool functionality were outside of scope.

3 | Technical Assessment

Withdrawal Slippage Enforcement

The Stake Pool program derives a withdrawal amount from the pool tokens burned after fees. When withdrawing the final stake account of a validator, the program may reduce that amount to the account's actual lamport balance, if it is inside of the bounds of one pool token worth of lamports. Before PR #883, the program checked the user's `minimum_lamports_out` before this reduction. The instruction could therefore succeed even though its final output was below the user-specified minimum.

PR #883 moves the check to after withdrawal-source selection. The comparison consequently applies to the amount the user actually receives. Neodyme found no issue with the implementation.

Pool-Mint Freeze Authority

PR #884 removes the rejection of pool mints that have a configured freeze authority. This change only affects newly created stake pools and does not affect old pools with no freeze authority configured.

Allowing a freeze authority for the pool mint changes the trust model of the stake pool, as the freeze authority can freeze the token account of a pool user and therefore prevent him from withdrawing his stake out of the pool.

As a result of the audit we advised Anza to make this new trust assumption more visible. Therefore the docs were changed and the official CLI warns users before depositing into a pool with a freezable mint.

4 | About Neodyme

Security is difficult.

To understand and break complex things, you need a certain type of people: people who thrive in complexity, who love to play around with code, and who do not stop exploring until they fully understand every aspect of it. That's us.

Our team never outsources audits. Having found over 80 high- or critical-severity bugs in Solana's core code itself, we believe that Neodyme hosts the most qualified auditors for Solana programs. We have also found and disclosed critical vulnerabilities in many of Solana's top projects and responsibly disclosed issues that could have resulted in the theft of over \$10B in TVL on the Solana blockchain.

All of our team members have a background in competitive hacking. During hacking competitions known as CTFs, we competed and collaborated while finding vulnerabilities, breaking encryption, reverse engineering complex algorithms, and much more. Many of our team members have won national and international competitions and continue to rank highly in some of the world's hardest CTF events.

In 2020, some of our members started experimenting with validators and became active members of the early Solana community. After reporting several bugs, the Solana Foundation contracted us for source-code auditing in 2021. As a result, Neodyme was born.

